AIF-C01: Security, Compliance, and Governance for AI Solutions

Exam-focused notes. Format for every item: **Definition → Why/when → Key points → Exam trap**.

PART 1: STRATEGIC GUIDANCE

1.1 Why security, governance, and compliance matter for AI

Definition: Security protects AI systems and data from attack. Governance sets the rules for how AI is built and used. Compliance proves you follow laws and standards.

Why it matters / when: AI uses huge amounts of (often personal) data, makes decisions that affect people, and creates new attack surfaces (prompts, training data, model weights). Apply it from day one, not after launch.

Key points

- Risks: data leaks, bias, hallucinations, misuse, legal fines, loss of trust.
- AI adds new threats: prompt injection, data poisoning, model theft.
- Governance covers the whole lifecycle: data → training → deployment → monitoring → retirement.
- Compliance = proof (reports, logs, documentation), not just intent.
- Responsible AI pillars: fairness, explainability, privacy and security, transparency, robustness, governance, safety.

Exam trap: Security vs Governance vs Compliance. **Security = protect, Governance = rules and accountability, Compliance = prove you meet external requirements.**

1.2 Shared Responsibility Model for AI workloads

Definition: AWS secures the cloud infrastructure; you secure what you put and run in it.

Why it matters / when: The exam asks "who is responsible for X?" The split changes with how managed the service is.

Key points

- **AWS = security OF the cloud:** hardware, data centers, network, managed service infrastructure (e.g., Bedrock service, model hosting infrastructure).
- **Customer = security IN the cloud:** your data, prompts, IAM permissions, encryption choices, guardrails, fine-tuning data, application code, output use.
- More managed (Bedrock, Rekognition, Comprehend) = AWS handles more. More control (SageMaker, EC2 self-hosted model) = you handle more (OS, patches, endpoint config, network).
- Bedrock: your prompts and outputs are not used to train base models or shared with model providers.
- Customer always owns: who can access, what data is used, and whether outputs are safe and lawful.

Exam trap: Responsibility for **model behavior and data use**. **AWS does not check whether your prompts, data, or outputs are lawful or unbiased. That is always the customer.** Also do not confuse this with the *Responsible AI* concept (fairness etc.).

PART 2: GOVERNANCE AND COMPLIANCE

2.1 Compliance standards for AI

ISO (27001, 27701, 42001)

Definition: International standards. 27001 = information security management system (ISMS), 27701 = privacy management, **ISO/IEC 42001 = AI management system (AIMS)**. **Why/when:** Show customers you manage security, privacy, and AI risk systematically. AWS holds 42001 for several AI services (e.g., Bedrock). **Key points**

- 27001: security controls and process.
- 27701: extends 27001 for privacy (PII).
- 42001: first AI-specific management standard (governance, risk, transparency).
- Certifiable by an auditor. **Exam trap:** ISO 27001 vs 42001. **27001 = information security in general; 42001 = managing AI systems specifically.**

SOC (SOC 1, 2, 3)

Definition: Audit reports on a service organization's controls. **Why/when:** Customers ask for proof of trustworthy operations. **Key points**

- SOC 1: financial reporting controls.
- **SOC 2: security, availability, processing integrity, confidentiality, privacy** (most relevant to AI/cloud).
- SOC 3: public summary of SOC 2.
- Get AWS's SOC reports from **AWS Artifact**. **Exam trap:** SOC 2 vs ISO 27001. **SOC = audit report (attestation); ISO = certification against a standard.**

GDPR

Definition: EU law protecting personal data of people in the EU. **Why/when:** Any AI using personal data of EU residents, wherever your company is. **Key points**

- Consent, purpose limitation, data minimization.
- Rights: access, correction, **erasure (right to be forgotten)**, portability.
- Restricts transfer of data outside the EU (residency concern).
- Limits fully automated decisions with major effects (right to human review).
- Large fines (up to 4% of global turnover or €20M). **Exam trap:** GDPR vs HIPAA. **GDPR = EU personal data of any kind; HIPAA = US health data only.**

HIPAA

Definition: US law protecting Protected Health Information (PHI). **Why/when:** AI handling patient data (healthcare, insurance). **Key points**

- Sign a **Business Associate Addendum (BAA)** with AWS (via Artifact).
- Use only **HIPAA-eligible services** for PHI.
- Requires encryption, access control, audit logs.
- Customer must configure services correctly. **Exam trap:** "HIPAA compliant service." **AWS services are HIPAA *eligible*; compliance depends on how you use them.**

NIST AI Risk Management Framework (AI RMF)

Definition: Voluntary US framework for managing AI risks. **Why/when:** Structuring an internal AI risk program. **Key points**

- Four functions: **Govern, Map, Measure, Manage**.
- Focus on trustworthy AI (valid, safe, secure, explainable, private, fair).
- Voluntary, not law.
- Sector-neutral. **Exam trap:** NIST AI RMF vs EU AI Act. **NIST = voluntary guidance; EU AI Act = binding law with penalties.**

EU AI Act

Definition: EU regulation classifying AI systems by risk level. **Why/when:** Selling or using AI in the EU. **Key points**

- **Risk tiers: Unacceptable (banned, e.g., social scoring) → High (strict rules, e.g., hiring, credit, medical) → Limited (transparency, e.g., chatbots must disclose AI) → Minimal.**
- High-risk needs risk management, data governance, documentation, human oversight, logging.
- Special rules for general-purpose AI (foundation models).
- Heavy fines. **Exam trap:** EU AI Act vs GDPR. **AI Act regulates the AI system by risk; GDPR regulates personal data.** Both can apply together.

2.2 AWS services for governance and compliance

AWS Artifact

Definition: Self-service portal for AWS compliance reports and agreements. **Why/when:** Auditor asks for AWS's SOC/ISO/PCI report, or you need to accept a BAA. **Key points**

- Artifact Reports: SOC, ISO, PCI, etc.
- Artifact Agreements: BAA, GDPR DPA.
- Free, on-demand.
- Covers **AWS's** compliance, not yours. **Exam trap:** Artifact vs Audit Manager. **Artifact = AWS's own reports; Audit Manager = evidence about YOUR resources.**

AWS Config

Definition: Records resource configurations and checks them against rules. **Why/when:** Detect config drift and non-compliant resources (e.g., unencrypted S3 bucket). **Key points**

- Config rules (managed and custom), conformance packs.
- Configuration history and timeline.
- Auto-remediation via Systems Manager.
- Answers "what is the state of the resource, and is it compliant?" **Exam trap:** Config vs CloudTrail. **Config = resource state/changes; CloudTrail = who called which API.**

AWS Audit Manager

Definition: Continuously collects evidence to simplify audits. **Why/when:** Preparing for audits (including generative AI governance). **Key points**

- Prebuilt frameworks (SOC 2, HIPAA, GDPR, **AWS Generative AI best practices framework**).
- Auto-collects evidence from CloudTrail, Config, etc.
- Generates audit-ready reports.
- Assessments, controls, evidence folders. **Exam trap:** Audit Manager vs Config. **Config checks resources; Audit Manager packages evidence for an audit.**

AWS CloudTrail

Definition: Logs API calls and account activity. **Why/when:** Auditing who did what, when, from where (e.g., who invoked or changed a Bedrock model). **Key points**

- Records management events (default) and data events (optional).
- Stores logs in S3; can send to CloudWatch Logs.
- Log file integrity validation.
- Bedrock **model invocation logging** (prompts/responses) is a separate Bedrock setting to S3/CloudWatch. **Exam trap:** CloudTrail vs CloudWatch. **CloudTrail = audit of API activity; CloudWatch = performance metrics, logs, alarms.**

AWS Trusted Advisor

Definition: Checks your account against AWS best practices. **Why/when:** Quick review of security gaps and cost savings. **Key points**

- Categories: cost, performance, security, fault tolerance, service limits, operational excellence.
- Security checks: open security groups, public S3, root MFA.
- Gives recommendations, not fixes.
- More checks on Business/Enterprise support. **Exam trap:** Trusted Advisor vs Inspector. **Trusted Advisor = account-level best-practice advice; Inspector = software vulnerability scanning.**

Amazon Inspector

Definition: Automated vulnerability management service. **Why/when:** Scan compute workloads for known vulnerabilities (CVEs) and network exposure. **Key points**

- Scans EC2, ECR container images, Lambda functions.
- Continuous, automated, risk-scored findings.
- Integrates with Security Hub and EventBridge.
- Use to secure infrastructure hosting AI apps. **Exam trap:** Inspector vs GuardDuty. **Inspector = finds weaknesses before attack; GuardDuty = detects active threats.**

Amazon SageMaker Model Cards

Definition: Standard documentation of a model's purpose, data, and performance. **Why/when:** Transparency and audit; explain a model to stakeholders. **Key points**

- Records intended use, training details, evaluation results, risk rating, limitations.
- Versioned and can be exported (PDF).
- Supports governance and lineage.
- Part of SageMaker governance tools. **Exam trap:** Model Cards vs Model Dashboard. **Card = documentation of one model; Dashboard = portfolio view of many models.**

Amazon SageMaker Model Governance

Definition: Set of SageMaker tools for governing models across the lifecycle. **Why/when:** Control access, document, and monitor models at scale. **Key points**

- **Role Manager:** least-privilege roles by persona (data scientist, MLOps).
- **Model Cards:** documentation.
- **Model Dashboard:** central view of models and their monitoring status.
- Related: **Model Monitor** (drift), **Model Registry** (versions, approval status), **Clarify** (bias/explainability). **Exam trap:** Governance tools vs Monitor vs Clarify. **Monitor = drift in production; Clarify = bias and explainability; Governance = access, docs, oversight.**

2.3 Data governance strategies

Data quality

Definition: Data is accurate, complete, consistent, and timely. **Why/when:** Bad data means biased or wrong models. **Key points:** Validate at ingestion; profile and clean; set quality rules and thresholds; assign data owners. **Tools:** AWS Glue Data Quality, Glue DataBrew. **Exam trap:** Data quality vs data integrity. **Quality = fit for purpose; integrity = not tampered/corrupted.**

Data lifecycle

Definition: Managing data from creation to deletion. **Why/when:** Control cost and risk; delete what you no longer need. **Key points:** Stages: create → store → use → archive → delete; **S3 Lifecycle policies** move/expire objects; tiering (Glacier); include training data and model artifacts. **Exam trap:** Lifecycle vs retention. **Lifecycle = the moves and stages; retention = how long you must keep.**

Data retention

Definition: Rules for how long data is kept. **Why/when:** Legal/regulatory minimums and privacy maximums (GDPR minimization). **Key points:** Set by policy and law; **S3 Object Lock** (WORM) prevents deletion; **AWS Backup** for managed retention; keep audit logs long enough for regulation. **Exam trap:** Retention vs backup. **Retention = policy of how long; backup = a recoverable copy.**

Logging

Definition: Recording activity for accountability. **Why/when:** Prove what happened; investigate incidents. **Key points:** CloudTrail (API), CloudWatch Logs (app), **Bedrock model invocation logging** (prompts/responses), S3 access logs, VPC Flow Logs; protect logs (encrypt, restrict, integrity validation). **Exam trap:** Logging vs monitoring. **Logging = recording; monitoring = watching and alerting.**

Data residency

Definition: Data stays in specified geographic locations. **Why/when:** Sovereignty laws (e.g., GDPR). **Key points:** Pick the Region deliberately; data does not leave a Region unless you move it; use **SCPs (AWS Organizations)** to deny other Regions; watch cross-Region inference and replication settings. **Exam trap:** Residency vs sovereignty vs encryption. **Residency = where data sits; encryption protects it but does not control location.**

Monitoring and observation

Definition: Continuously tracking system and model health and behavior. **Why/when:** Catch drift, misuse, cost, and errors early. **Key points: CloudWatch** (metrics, alarms, Bedrock runtime metrics), **SageMaker Model Monitor** (data/model drift, quality), CloudTrail for audit trail, review for bias and abnormal usage. **Exam trap:** Model Monitor vs Clarify. **Monitor = drift over time; Clarify = bias/explainability.**

2.4 Approaches for implementing governance strategies

Policies

Definition: Written rules for AI use, data handling, and access. **Why/when:** Everyone needs the same standards. **Key points:** Acceptable-use policy; data classification; model approval process; incident response; assign owners. **Exam trap:** Policy vs framework. **Policy = specific rule; framework = the structure that organizes policies and processes.**

Review cadence

Definition: Regular scheduled reviews of AI systems and policies. **Why/when:** Models drift; regulations change. **Key points:** Periodic model and bias reviews; audits; review after major changes/incidents; document outcomes. **Exam trap:** Review vs monitoring. **Review = scheduled human assessment; monitoring = continuous automated tracking.**

Transparency standards

Definition: Clear disclosure about how AI works and is used. **Why/when:** Build trust; meet law (EU AI Act disclosure). **Key points:** Model Cards; disclose AI use to users; document data sources and limits; explainability tools; cite sources. **Exam trap:** Transparency vs explainability. **Transparency = openness about the system; explainability = why a specific output was produced.**

Team training

Definition: Educating staff on AI risks, policies, and tools. **Why/when:** People cause many incidents. **Key points:** Role-based training; cover responsible AI, privacy, prompt safety; refresh regularly; training on approved tools. **Exam trap:** Training is a **governance control (people)**, not a technical control like Guardrails.

Governance frameworks

Definition: Structured approach to organize AI governance. **Why/when:** Scale governance across teams. **Key points:** Governance board/committee; clear roles; use **NIST AI RMF, ISO 42001**; AWS resources: **Generative AI Security Scoping Matrix**, Cloud Adoption Framework for AI; align to risk level. **Exam trap:** Framework vs standard. **Framework = guidance to organize; standard (ISO) = certifiable requirements.**

PART 3: SECURING AI SYSTEMS

3.1 Security and privacy considerations

Threat detection

Definition: Finding active malicious activity. **Why/when:** Compromised credentials, unusual API use. **Key points:** **Amazon GuardDuty** (ML anomaly detection on CloudTrail, VPC Flow, DNS); Security Hub aggregates; CloudWatch alarms. **Exam trap:** Detection vs prevention. **GuardDuty detects; IAM/Guardrails/VPC prevent.**

Vulnerability management

Definition: Finding and fixing weaknesses. **Why/when:** Patch software hosting AI apps. **Key points:** **Amazon Inspector** scans EC2/ECR/Lambda; patch regularly; scan dependencies and container images; prioritize by risk score. **Exam trap:** Inspector scans **software**; Macie scans **data**.

Infrastructure protection

Definition: Securing network and compute. **Why/when:** Limit exposure of endpoints and data paths. **Key points:** VPC, subnets, security groups; **PrivateLink** for private access; AWS WAF/Shield for public endpoints; least-privilege IAM; encryption. **Exam trap:** Security group vs NACL: SG is stateful at instance level; NACL is stateless at subnet level.

Prompt injection

Definition: Attacker crafts input that overrides the model's instructions. **Why/when:** Any LLM app taking user or external content. **Key points:** Direct (user types it) and indirect (hidden in documents/web pages); mitigate with **Bedrock Guardrails prompt-attack filter**, input validation, separating system and user prompts, least-

privilege for agent tools, human approval for risky actions. **Exam trap:** Prompt injection vs jailbreak. **Injection overrides app instructions; jailbreak bypasses the model's safety training** (they overlap; the exam mostly says injection).

Data poisoning

Definition: Attacker corrupts training/fine-tuning/RAG data to change model behavior. **Why/when:** Any pipeline using external or user-generated data. **Key points:** Happens **before/during training** (or in the knowledge base); defend with trusted sources, validation, access control on data stores, integrity checks, lineage, monitoring for drift. **Exam trap:** Poisoning vs prompt injection. **Poisoning attacks training data (pre-deployment); injection attacks the prompt at runtime.**

Model theft

Definition: Stealing model weights or copying the model via queries (extraction). **Why/when:** Proprietary or fine-tuned models. **Key points:** Restrict access with IAM; encrypt model artifacts with KMS; private endpoints; rate limiting and monitoring of unusual query patterns; CloudTrail auditing. **Exam trap:** Theft vs data leakage. **Theft = the model is taken; leakage = data comes out of the model.**

Sensitive data leakage

Definition: Model exposes PII or confidential data in outputs. **Why/when:** Training on sensitive data, RAG over private docs. **Key points:** Discover with **Macie**; mask/redact before training; **Guardrails sensitive information filters** on input and output; least-privilege access to knowledge bases; avoid putting secrets in prompts. **Exam trap:** Leakage via **model output** (Guardrails) vs leakage via **storage** (Macie, S3 policies, KMS).

3.2 AWS services and features for securing AI

AWS IAM

Definition: Controls who can do what on which resources. **Why/when:** Always; foundation of access control. **Key points:** Least privilege; roles over long-term keys; policies restrict model access (e.g., bedrock:InvokeModel on specific models); MFA; SageMaker Role Manager. **Exam trap:** IAM vs KMS. **IAM decides who can access; KMS controls the keys used to encrypt.**

Amazon Macie

Definition: ML-based discovery of sensitive data in S3. **Why/when:** Find PII in training data buckets before use. **Key points:** Detects PII, credentials, financial data; S3 only; inventories buckets and flags public/unencrypted ones; findings to Security Hub/EventBridge. **Exam trap:** Macie vs Comprehend. **Macie finds sensitive data at rest in S3; Comprehend detects/redacts PII in text you send it.**

AWS KMS

Definition: Creates and manages encryption keys. **Why/when:** Encrypt data, model artifacts, logs at rest. **Key points:** AWS-managed vs **customer-managed keys (CMK)** for more control; key policies and rotation; integrates with S3, SageMaker, Bedrock (custom models, knowledge bases); CloudTrail logs key use. **Exam trap:** KMS vs Secrets Manager. **KMS manages encryption keys; Secrets Manager stores credentials/API keys.**

AWS PrivateLink

Definition: Private connectivity to services via interface VPC endpoints. **Why/when:** Call Bedrock/SageMaker without traversing the public internet. **Key points:** Traffic stays on the AWS network; no internet gateway/NAT needed; endpoint policies restrict access; supports Bedrock and SageMaker APIs. **Exam trap:** PrivateLink vs VPC. **VPC is your private network; PrivateLink is the private connection to a service from your VPC.**

Amazon VPC

Definition: Logically isolated virtual network. **Why/when:** Isolate training jobs, endpoints, and data. **Key points:** Subnets, route tables, security groups, NACLs; SageMaker can run in VPC (network isolation); VPC Flow Logs; VPC endpoints. **Exam trap:** VPC vs PrivateLink (above). Security Groups vs NACLs (above).

AWS Secrets Manager

Definition: Stores and rotates secrets. **Why/when:** API keys for third-party model APIs, DB credentials for RAG stores. **Key points:** Automatic rotation; encrypted with KMS; fine-grained IAM access; never hard-code secrets. **Exam trap:** Secrets Manager vs Parameter Store. **Secrets Manager = built-in rotation, for secrets; Parameter Store = general config, simpler/cheaper.**

Amazon Bedrock Guardrails

Definition: Configurable safeguards for generative AI inputs and outputs. **Why/when:** Block harmful content, PII, off-topic use, prompt attacks. **Key points:** Content filters (hate, violence, etc.); **denied topics**; word filters; **sensitive information filters (block or mask PII)**; **prompt-attack filter**; **contextual grounding checks** (reduce hallucination); works with any model via the **ApplyGuardrail API**. **Exam trap:** Guardrails vs IAM vs Macie. **Guardrails filter model inputs/outputs at runtime; IAM controls access; Macie scans stored data.**

Amazon GuardDuty

Definition: Managed threat detection. **Why/when:** Detect compromised credentials, suspicious API calls, malware. **Key points:** Analyzes CloudTrail, VPC Flow Logs, DNS logs; no agents; findings by severity; S3 and malware protection options. **Exam trap:** GuardDuty vs Inspector (above). **GuardDuty = threats now; Inspector = vulnerabilities.**

Encryption at rest and in transit

Definition: At rest = protecting stored data. In transit = protecting data moving across networks. **Why/when:** Required by nearly every standard. **Key points:** At rest: **KMS** with S3, EBS, SageMaker; in transit: **TLS/HTTPS** (AWS APIs use it by default), ACM certificates; Bedrock encrypts data at rest and in transit; use customer-managed keys for control. **Exam trap:** Encryption vs masking. **Encryption is reversible with a key; masking hides values (often irreversibly) in the data itself.**

3.3 Data and model lineage

Source citation

Definition: Model output shows the documents it used. **Why/when:** Trust and verification in RAG. **Key points:** **Knowledge Bases for Amazon Bedrock** returns source attribution; lets users verify answers; reduces hallucination risk; supports audits. **Exam trap:** Citation vs lineage. **Citation = source of a single answer; lineage = full history of data/model.**

Data origin documentation

Definition: Recording where data came from and how it changed. **Why/when:** Prove data was legitimate and licensed; trace poisoning. **Key points:** Glue Data Catalog metadata; **SageMaker ML Lineage Tracking**; version datasets (S3 versioning); record licenses, collection method, transformations. **Exam trap:** Data lineage vs data catalog. **Catalog = inventory of data; lineage = its journey and transformations.**

SageMaker Model Cards (in lineage)

Definition: See 2.2. Documents training data, evaluation, intended use. **Why/when:** Link model to its data and decisions. **Key points:** Captures training datasets and metrics; version history; used in audits and approvals.

Exam trap: Model Card vs Model Registry. **Card = documentation; Registry = versioned model storage and approval.**

Role in audit and trust

Key points: Lets auditors trace output → model → data; supports regulation (EU AI Act documentation); helps investigate bias/poisoning; builds user and stakeholder trust. **Exam trap:** Lineage answers **"where did this come from?"**; CloudTrail answers **"who did this?"**

3.4 Best practices for secure data engineering

Data quality

Definition: Accurate, complete, representative data. **Why/when:** Prevents bias and errors. **Key points:** Validate and clean; check class balance/representativeness; Glue Data Quality; document known gaps. **Exam trap:** Quality vs integrity (above).

Privacy-enhancing technologies (PETs)

Definition: Techniques that use data while protecting privacy. **Why/when:** Train/analyze on sensitive data. **Key points: Differential privacy** (adds noise), **federated learning** (train without moving data), **homomorphic encryption** (compute on encrypted data), tokenization, **AWS Clean Rooms** (collaborate without sharing raw data). **Exam trap:** Federated learning keeps data local; differential privacy protects individuals in results. Not the same.

Access control

Definition: Only authorized identities reach data. **Why/when:** Prevent leaks and tampering. **Key points:** IAM least privilege; **Lake Formation** fine-grained (row/column) access; separate roles for data engineers vs scientists; S3 Block Public Access; MFA. **Exam trap:** IAM (service-level) vs Lake Formation (data-level row/column).

Data integrity

Definition: Data is not altered or corrupted. **Why/when:** Prevent poisoning and errors. **Key points:** S3 versioning; checksums/hashing; CloudTrail log validation; Object Lock; restrict write access. **Exam trap:** Integrity vs confidentiality. **Integrity = unchanged; confidentiality = unseen.**

Data anonymization / masking

Definition: Removing or hiding identifiers. **Why/when:** Use data for training without exposing individuals. **Key points:** Anonymization removes identity (ideally irreversible); **pseudonymization** replaces IDs but can be reversed (still personal data under GDPR); masking hides values (e.g., ****1234); tools: Comprehend PII redaction, Glue DataBrew, Macie (discover), Guardrails (mask in outputs). **Exam trap: Anonymization = cannot re-identify; pseudonymization = can re-identify with extra info.**

COMPARISON TABLE: AWS SERVICES

Service	Purpose	Use when
AWS Artifact	AWS compliance reports and agreements	You need AWS's SOC/ISO report or a BAA
AWS Config	Resource configuration tracking and rules	Check compliance/drift of resources
AWS Audit Manager	Automated audit evidence	Preparing audits, including gen AI frameworks
AWS CloudTrail	API activity audit log	Who did what and when

Service	Purpose	Use when
AWS Trusted Advisor	Best-practice checks	Quick account-wide security/cost review
Amazon Inspector	Vulnerability scanning	Scan EC2, ECR, Lambda for CVEs
SageMaker Model Cards	Model documentation	Document purpose, data, risks
SageMaker Model Governance	Role Manager, Cards, Dashboard	Govern models at scale
AWS IAM	Access control	Restrict who can use models/data
Amazon Macie	Sensitive data discovery in S3	Find PII in training data
AWS KMS	Key management	Encrypt data and models
AWS PrivateLink	Private service connectivity	Reach Bedrock without the internet
Amazon VPC	Isolated network	Isolate AI workloads
AWS Secrets Manager	Secret storage and rotation	Store API keys and credentials
Bedrock Guardrails	Input/output safeguards	Filter harmful content, mask PII, block prompt attacks
Amazon GuardDuty	Threat detection	Detect compromised credentials/suspicious activity
Amazon CloudWatch	Metrics, logs, alarms	Monitor performance and usage
SageMaker Model Monitor	Drift detection	Model quality degrading in production
SageMaker Clarify	Bias and explainability	Check fairness and explain predictions
AWS Lake Formation	Data lake access control	Row/column-level permissions

CHEAT SHEET: SCENARIO → SERVICE

#	Scenario	Answer
1	Auditor wants AWS's SOC 2 report	AWS Artifact
2	Need to sign a HIPAA BAA	AWS Artifact
3	Continuously collect evidence for a gen AI audit	AWS Audit Manager
4	Find who invoked or changed a Bedrock resource	AWS CloudTrail
5	Detect an S3 bucket that became unencrypted	AWS Config
6	Document a model's intended use and risk rating	SageMaker Model Cards
7	Give data scientists least-privilege SageMaker roles	SageMaker Role Manager
8	See all models and their monitoring status in one place	SageMaker Model Dashboard
9	Find PII in S3 training data	Amazon Macie
10	Block PII and harmful content in chatbot responses	Bedrock Guardrails
11	Stop prompt-attack attempts on a chatbot	Bedrock Guardrails (prompt-attack filter)
12	Call Bedrock without traversing the internet	AWS PrivateLink
13	Store and rotate a third-party API key	AWS Secrets Manager
14	Encrypt model artifacts with your own keys	AWS KMS (customer-managed key)
15	Detect unusual API calls from stolen credentials	Amazon GuardDuty
16	Scan Lambda and container images for CVEs	Amazon Inspector
17	Quick check for public S3 buckets and missing root MFA	AWS Trusted Advisor
18	Detect data drift in a deployed model	SageMaker Model Monitor
19	Check a model for bias and explain predictions	SageMaker Clarify
20	Show users which documents an answer came from	Knowledge Bases for Bedrock (source citations)

COMPLIANCE STANDARDS QUICK REFERENCE

Standard	Focus	Applies to
ISO/IEC 27001	Information security management	Any organization
ISO/IEC 27701	Privacy management	Organizations handling PII
ISO/IEC 42001	AI management system	Organizations developing/using AI
SOC 1	Financial reporting controls	Service providers affecting finances
SOC 2	Security, availability, confidentiality, privacy	Cloud/SaaS providers
SOC 3	Public summary of SOC 2	General public marketing
GDPR	Personal data protection	EU residents' data, worldwide
HIPAA	Protected health information	US healthcare and business associates
NIST AI RMF	Voluntary AI risk management (Govern, Map, Measure, Manage)	Any organization (US-origin)
EU AI Act	Risk-based AI regulation	AI placed on or used in the EU market

KNOWLEDGE CHECK: 15 MCQs

Governance and compliance (Q1 to Q8)

Q1. An auditor asks for AWS's SOC 2 report. Where do you get it? A. AWS Audit Manager B. AWS Artifact C. AWS Config D. AWS Trusted Advisor **Answer: B.** Artifact provides AWS's compliance reports. Audit Manager collects evidence about your own resources.

Q2. A company must continuously gather evidence for a generative AI governance audit. Which service? A. AWS CloudTrail B. Amazon Inspector C. AWS Audit Manager D. Amazon Macie **Answer: C.** Audit Manager automates evidence collection and includes a generative AI framework.

Q3. A security team needs to know which IAM user called a Bedrock API yesterday. Which service? A. AWS Config B. AWS CloudTrail C. Amazon CloudWatch D. AWS Trusted Advisor **Answer: B.** CloudTrail records API calls (who, what, when). Config shows resource state.

Q4. Which SageMaker feature documents a model's intended use, training data, evaluation results, and risk rating? A. Model Monitor B. Model Registry C. Model Cards D. Clarify **Answer: C.** Model Cards are structured model documentation for transparency and audit.

Q5. Which framework organizes AI risk management into Govern, Map, Measure, and Manage? A. EU AI Act B. ISO 27001 C. NIST AI RMF D. HIPAA **Answer: C.** NIST AI RMF is a voluntary framework with these four functions.

Q6. Which standard is the first certifiable management system specifically for AI? A. ISO/IEC 27001 B. ISO/IEC 42001 C. SOC 2 D. ISO/IEC 27701 **Answer: B.** ISO/IEC 42001 defines an AI management system.

Q7. A hospital wants to use AWS services for AI on patient data. What must it do first? A. Enable GuardDuty B. Sign a BAA and use HIPAA-eligible services C. Move to a public subnet D. Disable logging **Answer: B.** HIPAA requires a BAA and eligible services; correct configuration is the customer's job.

Q8. Under the AWS shared responsibility model, who is responsible for the legality and bias of the data used to fine-tune a model on Bedrock? A. AWS B. The model provider C. The customer D. The auditor **Answer: C.** The customer is responsible for their data and how outputs are used.

Securing AI systems (Q9 to Q15)

Q9. A team wants to find PII stored in S3 buckets that will be used for training. Which service? A. Amazon Macie B. Amazon Inspector C. AWS KMS D. AWS Shield **Answer: A.** Macie uses ML to discover sensitive data in S3.

Q10. A chatbot must never return credit card numbers or off-topic answers. Which feature helps? A. AWS PrivateLink B. Bedrock Guardrails C. AWS Config D. Amazon VPC **Answer: B.** Guardrails offer sensitive information filters and denied topics on inputs and outputs.

Q11. A company needs to call Bedrock from its VPC without sending traffic over the public internet. What should it use? A. Internet gateway B. AWS PrivateLink (interface VPC endpoint) C. AWS Artifact D. NAT gateway **Answer: B.** PrivateLink keeps traffic on the AWS network.

Q12. Which service detects that stolen credentials are being used to make unusual API calls? A. Amazon Inspector B. Amazon GuardDuty C. AWS Trusted Advisor D. Amazon Macie **Answer: B.** GuardDuty is threat detection using CloudTrail, VPC Flow, and DNS logs. Inspector finds vulnerabilities.

Q13. Where should an application store a third-party model API key with automatic rotation? A. In the source code B. AWS Secrets Manager C. S3 public bucket D. AWS Config **Answer: B.** Secrets Manager stores and rotates secrets.

Q14. An attacker injects malicious records into a training dataset to change model behavior. This is: A. Prompt injection B. Model theft C. Data poisoning D. Model inversion **Answer: C.** Data poisoning corrupts training data. Prompt injection happens at runtime through the prompt.

Q15. A team wants to train across hospitals without moving patient data to a central place. Which technique? A. Federated learning B. Data masking C. Tokenization D. Data lifecycle policy **Answer: A.** Federated learning is a privacy-enhancing technology that keeps data local.

LAST-MINUTE REVISION SHEET: TOP 20

1. **Shared responsibility:** AWS = security OF the cloud; customer = security IN the cloud (data, prompts, IAM, outputs).
2. More managed service (Bedrock) = less customer work; SageMaker/EC2 = more customer work.
3. **ISO 42001 = AI management system;** ISO 27001 = information security; 27701 = privacy.
4. **SOC 2** = security, availability, confidentiality; get reports from **Artifact**.
5. **GDPR** = EU personal data (erasure, minimization, transfers); **HIPAA** = US health data (BAA, eligible services).
6. **NIST AI RMF** = Govern, Map, Measure, Manage; voluntary.
7. **EU AI Act** = risk tiers (unacceptable banned, high, limited, minimal); binding law.
8. **Artifact = AWS's reports; Audit Manager = your evidence.**
9. **Config = resource state/compliance; CloudTrail = who did what (API).**
10. **CloudTrail = audit; CloudWatch = metrics/monitoring.**
11. **Trusted Advisor = best-practice advice; Inspector = vulnerability scanning; GuardDuty = threat detection.**
12. **Model Cards = document one model; Dashboard = view all; Role Manager = persona roles; Monitor = drift; Clarify = bias.**
13. Data governance: quality, lifecycle (S3 Lifecycle), retention (Object Lock), logging, residency (Region + SCP), monitoring.
14. Governance approaches: policies, review cadence, transparency, training, frameworks.

15. **Prompt injection = runtime attack on prompts; data poisoning = attack on training data; model theft = stealing model; leakage = data exposed by model.**
16. **Bedrock Guardrails** = content filters, denied topics, PII filters, prompt-attack filter, grounding checks, ApplyGuardrail API.
17. **Macie = sensitive data in S3; Comprehend = PII in text; Guardrails = model I/O.**
18. **IAM = who can access; KMS = encryption keys; Secrets Manager = credentials.**
19. **VPC = private network; PrivateLink = private connection to a service;** encrypt at rest (KMS) and in transit (TLS).
20. Lineage answers "where did this come from" (citations, ML Lineage, Model Cards); **anonymization is irreversible, pseudonymization is reversible;** PETs: differential privacy, federated learning, Clean R